

Cloud Computing

UNIT-6

Cloud Security

Security challenges for cloud applications:

1. Authentication
2. Authorization
3. Security of data at rest
4. Security of data in motion
5. Data integrity
6. Auditing

Cloud Security

Authentication

- **Authentication refers to digitally** confirming the identity of the entity requesting access to some protected information.
- In traditional in house-IT environment authentication policies are under the control of the organization and the process of **confirming identity is usually restricted to the employees of the organization.**
- In cloud computing environments where applications and data are accessed over the internet, the **complexity of digital authentication mechanisms increases rapidly.**
- Alteration of authentication and authorization policies requires the involvement of the cloud service providers systems and services.

Cloud Security

Authorization

- Authorization refers to digitally specifying the access rights to the protected resources using access policies.
- In a traditional in house IT environment, the access policies are controlled by the organization and can be altered their convenience.

Ex : An organization can provide different access policies for different departments. Authorization in a cloud computing environments requires the use of the cloud service providers services for specifying the access policies.

Cloud Security

Security of data at rest

- Due to **multi-tenant environments used in the cloud**, the application and database servers of different applications belonging to different organizations can be provisioned **side-by-side increasing the complexity of securing the data**.
- Appropriate separation mechanisms are required to ensure the isolation between applications and data from different organizations.

Security of data in motion

- **In traditional data exchange policies all the data exchanged between the applications** and users remains within the organizations control and geographical boundaries.
- Organization believe that they have complete visibility of all the data exchanged and control the IT infrastructure.
- In the cloud model, the applications and the data are moved out of the in house IT infrastructure to the cloud provider.

Cloud Security

Security of data in motion (Contd ..)

- In such a scenario, organizations have to access their applications with the **data moving in and out of the cloud over the internet**.
- Therefore, appropriate security mechanisms are required to ensure the security of data in, and while in, motion.

Data Integrity

- Data integrity ensures that the data is not altered in an **unauthorized manner after it is created, transmitted or stored**.
- Due to the outsourcing of the **data storage in cloud computing environments, ensuring integrity of data is important**.
- Appropriate mechanisms are required for **detecting accidental and/or intentional changes in the data**.

Cloud Security

Auditing

- Auditing is very important for applications deployed in cloud computing environments.
- In traditional in house IT environments, organizations have complete visibility of their applications and accesses to the protected information.
- For cloud applications appropriate actions performed by the application users, including mobile users and devices such as wireless laptops and smart phones.

Cloud Security Architecture(CSA)

- The Cloud security alliance(CSA) provides a **Trusted Cloud Initiative(TCI) reference architecture for cloud security.**
- It is methodology and a set of tools that enable cloud application developers and security architects to assess where their internal IT and their cloud providers are in terms of security capabilities, and to plan a roadmap to meet the security needs of their business.

Sub domains of security and risk management are :

1. Governance, Risk management and compliance
2. Information security Management
3. Privilege Management Infrastructure
4. Threat and Vulnerability Management
5. Infrastructure protection Services
6. Data Protection
7. Policies and Standards

Cloud Security Architecture(CSA)



Fig : TCI reference Architecture of CSA

Cloud Security Architecture(CSA)

Governance, Risk management and compliance

- This sub domain deals with the identification and implementation of the appropriate organizational structures, processes and controls to maintain effective information security governance, risk management and compliance.

Information Security Management

- It deals with the implementation of appropriate measurements in order to minimize or eliminate the impact that security related threats and vulnerabilities might have on an organization.

Privilege Management Infrastructure

- The objective of this sub domain is to ensure that users have access and privileges required to execute their duties and responsibilities with identity and access management(IAM) functions such as identity management, authentication services, authorization services and privilege usage management.

Cloud Security Architecture(CSA)

Threat and Vulnerability Management (**privileged administrative roles in control**)

- This sub domain deals with **core security such as vulnerability management, threat management**, compliance testing and penetration testing.

Infrastructure Protection Services

- This sub domain is to secure Server, End-Point, Network and Application layers.

Data Protection

- This sub domain deals with data lifecycle management, **data leakage prevention, intellectual property protection** with digital rights management and cryptographic services such as key management and PKI/symmetric encryption.

Cloud Security Architecture(CSA)

Policies and Standards

- Security policies and standards are derived from risk-based business requirements and exist at a number of different levels including information security policy, Physical security policy, Business community policy, Infrastructure security policies, Application Security policies .

Authentication

- Authentication refers to conforming the digital identity of the entity requesting access to some protected information.
- The process of authentication involves, but it is not limited to, validating the at least one factor of identification of the entity to be authenticated.
- A factor can be something the entity or the user knows(password or pin), something the user has(such as a smart card), or some thing that can uniquely identify the user(finger prints).
- In multifactor authentication more than one of these factors are used for authentication .
- There are different authentication mechanisms like SSO, SAML-Token, kerberos, OTP etc.

Authentication

1. Single Sign-on(SSO)

- **Single sign-on (SSO)** enables users to access multiple systems or applications after signing in only once, for the first time.
- When a **user signs in, the user identity is recognized and there is no need to sign in again to access** related systems or applications.
- Since different systems or applications may be internally using different **authentication mechanisms, SSO** upon receiving initial credential translates to different credentials for different systems or applications.
- The **benefit of using SSO is that it reduces** human error and saves time spent in authenticating with different systems or applications for the same identity.

Authentication

SAML-Token :

- Security Assertion Markup Language (SAML) is an XML-based open standard data format for exchanging security information between an identity provider and a service provider.
- When a user tries to access the cloud application, a SAML request is generated and the user is redirected to the identity provider.
- The identity provider parses the SAML requests and authenticates the user.
- A SAML token is returned to the user, who then access the cloud application with the token.
- SAML prevents man-in-the-middle and reply attacks by requiring the use of SSL encryption when transmitting assertion and message.
- SAML also provides a digital signature mechanism that enables the assertion to have a validity time range to prevent replay attacks.

Authentication

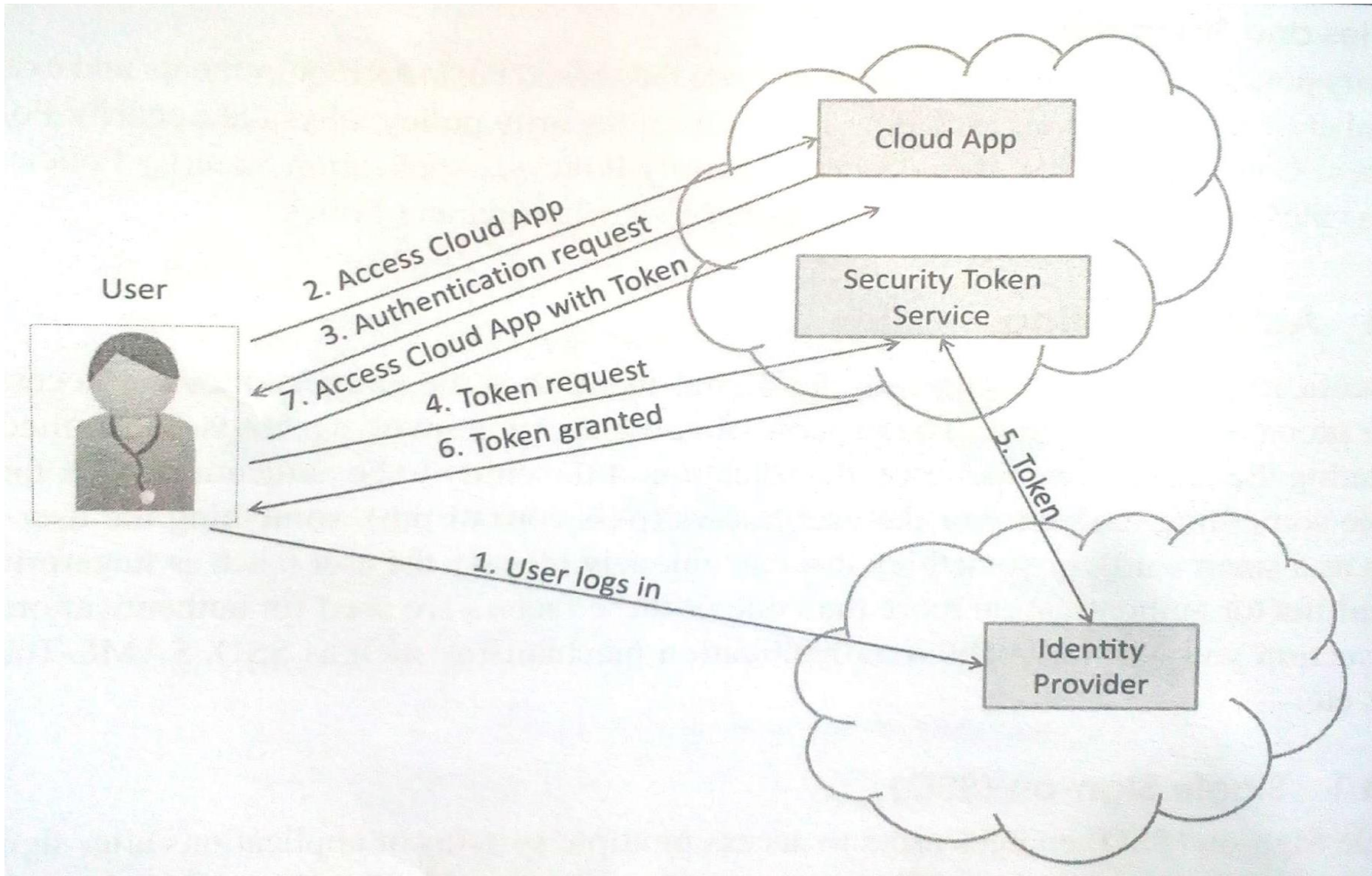


Fig : SAML-token based SSO authentication

Authentication

Kerberos

- Kerberos is an open authentication protocol .
- Kerberos uses tickets for authenticating client to a service that communicate over an un-secure network.
- Kerberos provides mutual authentication, i.e both the client and the server authenticate with each other.
- The Steps involved in authentication are :

Authentication

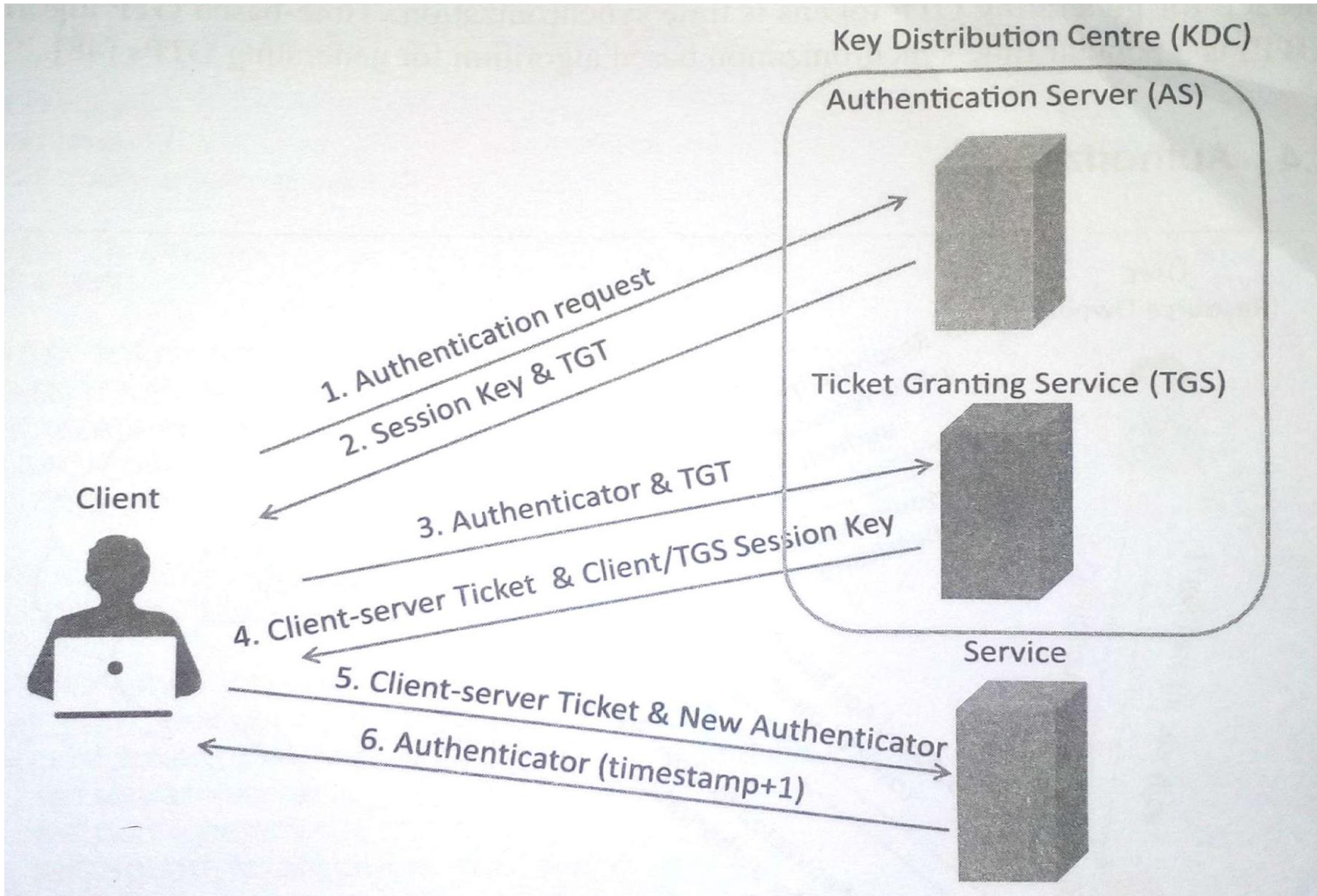


Fig : Kerberos Authentication flow

Authentication

Step1:

- The **client authenticates itself to the Authentication Server(AS)** that resides on the **Key Distribution Center (KDS)**.
- The **client does not need to send** the user password to the AS. Instead client sends a clear-text message to the AS containing the user ID to the AS requesting to Authenticate the user to the remote service.

Authentication

Step 2:

- The **AS checks if the client** is in the database and generates a client/TGS session key that will be used by the client and the remote service.
- The AS encrypts the session key with the users password.
- The KDC also prepares the **Ticket Granting Ticket(TGT)** (It includes the client ID , client network address, ticket validity period and the session key) and encrypts it using the secret key of the TGS.
- KDC then sends both the session key and TGT to the client on receiving the session key and TGT, the client decrypts the Client/TGS session key using its password and extracts the session key.
- The client can not decrypts the TGT as it does not know the secret key of the TGS.

Authentication

- **The client encrypts** the client ID and current time using the session key to prepare an authenticator.
- The client then sends the authenticator and the TGT that it received from the KDC to the TGS.

Step 3:

- **On receiving the authenticator** and TGT from the client, the TGS decrypts the TGT using its own secret key and retrieves the session key.
- The TGS then uses the session key to decrypt the authenticator and extracts the client ID and time.

Step 4:

- **The TGS then sends two pieces of data to the client.**
- The first piece contains the client-server ticket(which includes the client ID, client network address, validity period and Client/Server session key) encrypted using the service's secret key.

Authentication

- The second piece of data contains the Client/Server Session Key encrypted with the Client/TGS Session Key.

Step 5:

- On receiving the client-server ticket and Client/TGS Session Key from the TGS, the client has enough information to authenticate itself to the remote service.
- The client then sends two pieces of data to the remote service, such as client-server ticket which is encrypted using the services secret key and new authenticator which includes the client ID, time stamp and is encrypted using Client/Server Session Key.
- On receiving the client server ticket and new authenticator from the client, the remote service decrypts the client-server ticket using its own secret key and retrieves the Client/Server session key.
- Using session key, remote service decrypts the authenticator.

Authentication

- At this point the true identity of the client is confirmed to the remote service and it responds to the client with the time stamp found in client's authenticator plus 1, encrypted using the Client/Server session key.
- Step 6:
- On receiving the new authenticator from the remote service, the client decrypts it using the Client/Server Session Key and checks the timestamp.
- If the time stamp is correctly updated, the client can trust the server and start issuing service requests to the server.

Authentication

One Time Password(OTP)

- **One time password is another authentication** mechanism that uses passwords which are valid for single use only for a single transaction or session.
- **Authentication mechanism based on OTP** tokens are more secure because they are not vulnerable to replay attacks.
- **Text messaging(SMS)** is the most common delivery mode for OTP tokens.
- The most common approach for generating OTP tokens is time synchronization.
- **Time-based OTP** algorithm (TOTP) is a popular time synchronization based algorithm for generating OTPs.

Authorization

- Authorization refers to specifying the access rights to the protected resources using access policies.

OAuth

- **OAuth is an open standard for authorization** that allows resource owners to share their private resources stored on one site with another site without handing out the credentials.
- **In the OAuth model**, an application requests access to resources controlled by the resource owner ,the resource owner grants permission to access the resources in the form of a token and matching shared-secret.
- **Tokens make it unnecessary** for the resource owner to share its credentials with the application.
- Tokens can be issued with a restricted scope and limited lifetime, and revoked independently.

Authorization

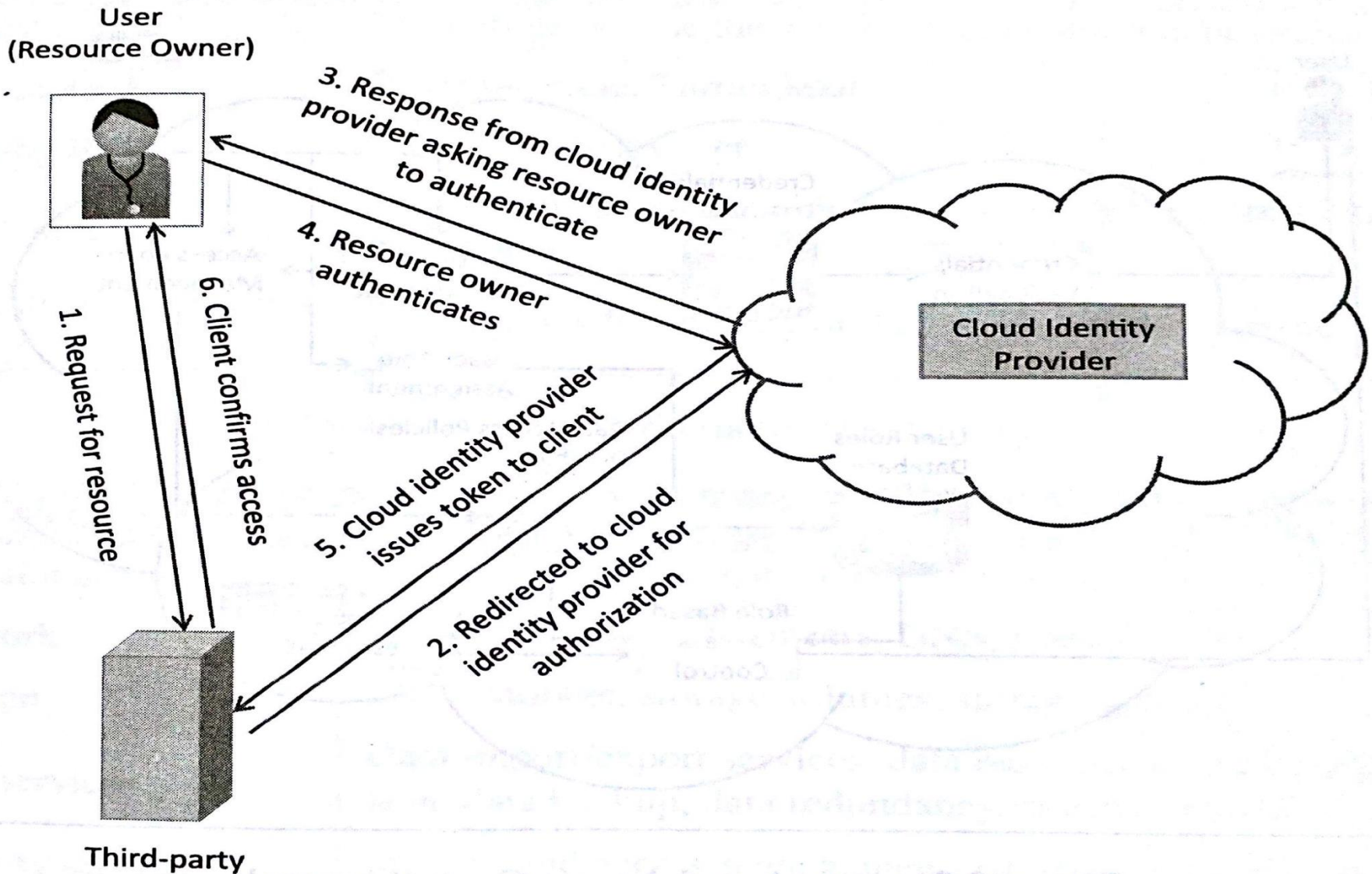


Fig : OAuth Example

Identity and Access Management

- Identity management provides consistent methods for digitally identifying persons and maintaining associated identity attributes for the users across multiple organizations.
- Access management deals with user privileges.
- Identity and access management deal with user identities, their authentication, authorization and access policies.
- Federated identity management allows users of one domain to securely access data or system of another domain seamlessly without the need for maintaining identity information separately for multiple domains.
- Federation is enabled through the use SSO mechanism such as SAML token or Kerberos.
- With the federated identity management the identity credentials stay with the identity provider at a trusted place and multiple applications from different organizations can use the identity credentials for user authentication.

Identity and Access Management

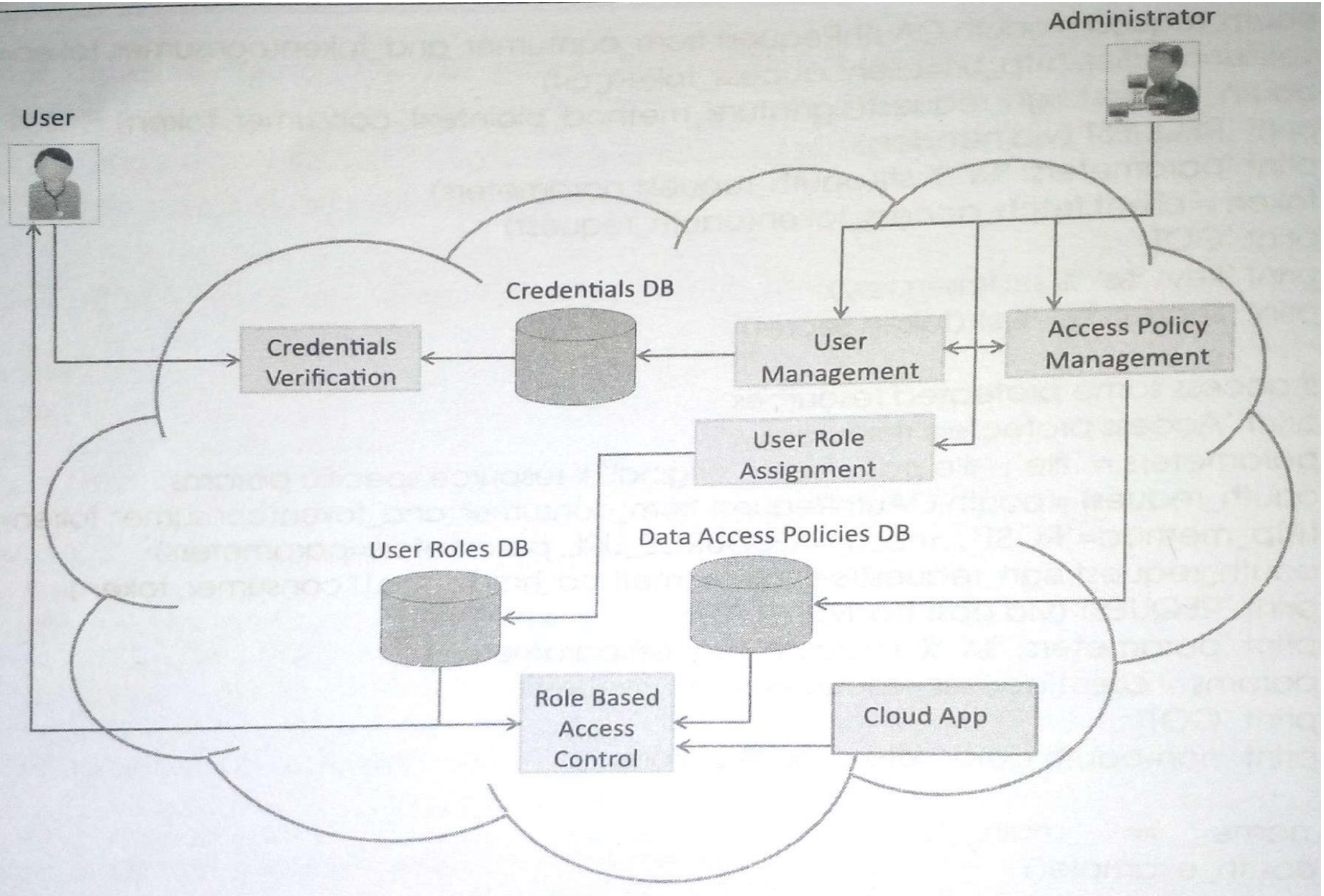


Fig : Role-based access control in the cloud

Identity and Access Management

- **Standardized access control** policies ensure confidentiality of data.
- Role-based access control approaches are used for restricting access to confidential information to authorized users.
- These access control policies allow defining different roles for different users.
- The role based access control framework provides access to application data to the users based on the assigned roles and data access policies.

Data Security

- Securing data in the cloud is critical for cloud applications as the data flows from applications to storage and vice versa.
- Cloud applications deal with both data at rest and data in motion.
- There are various types of threats that can exist for data in the cloud such as denial of service, replay attacks, man-in-the-middle attacks, unauthorized access/modification etc.

Securing Data at Rest

- Data at rest is the data that is stored in database in the form of tables/records, files on a file server or raw data on a distributed storage or storage area networks(SAN).
- Data at rest is secured by encryption.
- Encryption is the process of converting data from its original form to a scrambled form .
- Decryption converts data from cipher text to plain text.

Data Security

- Encryption can be of two types :
 1. Symmetric Encryption (Symmetric – key Algorithms)
 - It uses the same secret key for both encryption and decryption.
 - The secret key is shared between the sender and the receiver.
 - Symmetric key is best suited for securing data at rest since the data is accessed by known entities from known locations.

Some popular symmetric encryption algorithms:

1. Advanced Encryption Standard(AES)
2. Twofish
3. Blowfish
4. Triple Data encryption Standard(3DES)
5. Serpent
6. RC6
7. MARS

Data Security

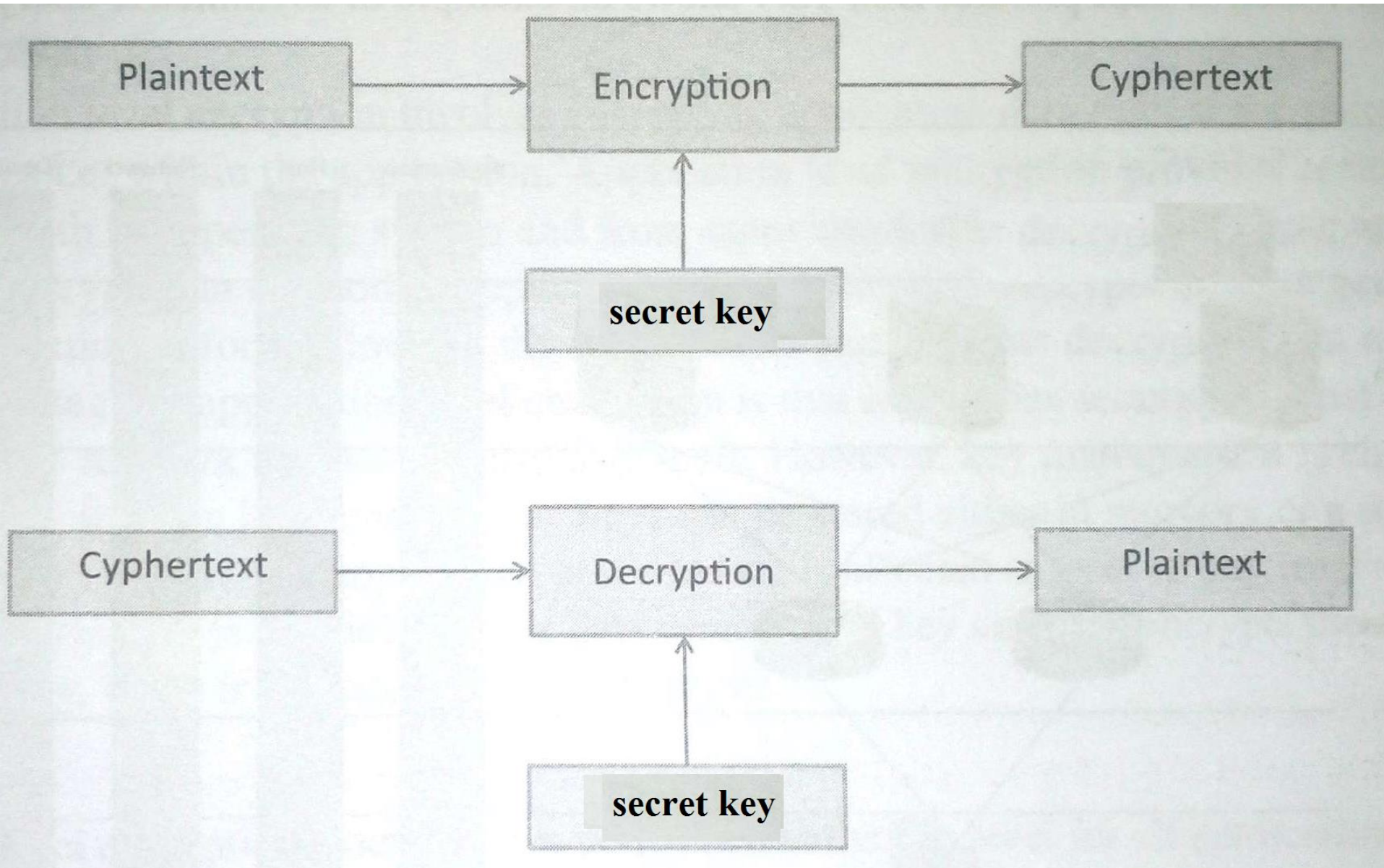


Fig: Symmetric Encryption using secret key

Data Security

2. Asymmetric Encryption (Public – key Algorithms)

- It uses two keys, one for encryption(public key) and other for decryption(private key).
- The two keys are linked to each other so that one key encrypts plaintext to cipher text and other decrypts cipher text back to plain text.
- Public key can be shared or published while the private key is known only to the user.
- Asymmetric encryption is best suited for securing data that is exchanged between two parties where symmetric encryption can be unsafe because the secret key has to be exchanged between the parties and anyone who manages to obtain the secret key can decrypt the data.

Data Security

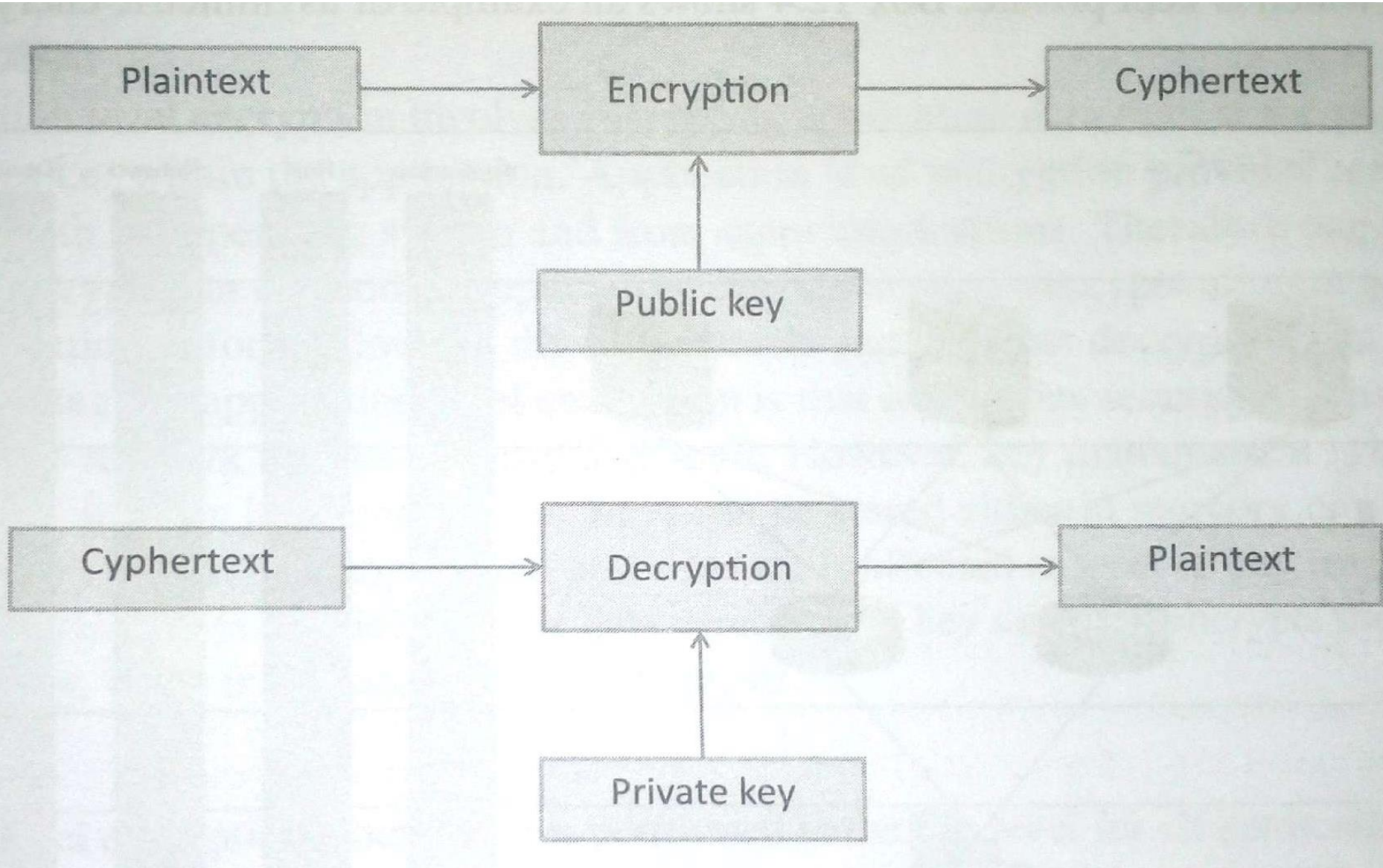


Fig: Asymmetric Encryption using public/private keys

Data Security

Encryption can be performed at various levels, they are :

1. Application

- Application level encryption involves encrypting application data right at the point where it originates that is within the application.
- Application level encryption provides security at the level of both the operating system and from other applications.
- Therefore one application cannot decrypt data of another application.
- An application encrypts all data generated in the application before it flows to the lower levels and presents decrypted data to the user.
- The advantage of application level encryption is that it provides security against operating system and network attacks and also data attacks.
- Key management is a challenging task for application level encryption.
- Key can be stored in the memory or a file or on a separate key server.

Data Security

2. Host

- In this encryption is performed at the file-level for all applications running on the host.
- Host level encryption can be done in software in which case additional computational resource is required for encryption or it can be performed with specialized hardware such as cryptographic accelerated card.
- The advantage of host level encryption is that it is highly secure and suited well for active data files across all applications running on a host.
- Key management can be challenging , keys are stored in the host memory or a separate key server.

Data Security

3. Network

- Network based encryption is best suited for cases where the threats to data are at the network or storage level and not at the application or host level.
- Network-level encryption is performed when moving the data from a creation point to its destination using specialized hardware that encrypts all incoming data in real time.
- The advantage of this network level encryption is that it is simple to implement and requires no changes in the existing data infrastructure.
- Keys are managed in hardware.
- The disadvantage of this encryption is that it is the least scalable of all the levels. As the data volume increases, a single encryption appliance can become a bottleneck.

Data Security

4. Device

- Device level encryption is performed on a disk controller or a storage server.
- Device level encryption is easy to implement and is best suited for cases where the primary concern about data security is to protect data residing on storage media.
- Device level encryption is operating system, application, host and even transport independent.
- Device level encryption requires no changes in the existing data infrastructure.
- Disadvantage of this method is that all data that is transmitted to and from the storage media is unencrypted.

Data Security

Securing Data at motion

- When the data flows between a client and a server over a potentially insecure network, is important to ensure data confidentiality and integrity.
- Data confidentiality means limiting the access to data so that only authorized recipients can access it.
- Data integrity ensures that the data is not altered in an unauthorized manner after it is created, transmitted or stored.
- Transport Layer Security(TLS) and Secure Socket Layer(SSL) are the mechanisms used for securing the data in motion.
- The working of TLS handshaking is like :
 1. **Client Hello** : The client sends a ClientHello message specifying the highest TLS protocol version it supports, a random number and the information on the private key encryption algorithms supported by the client.

Data Security

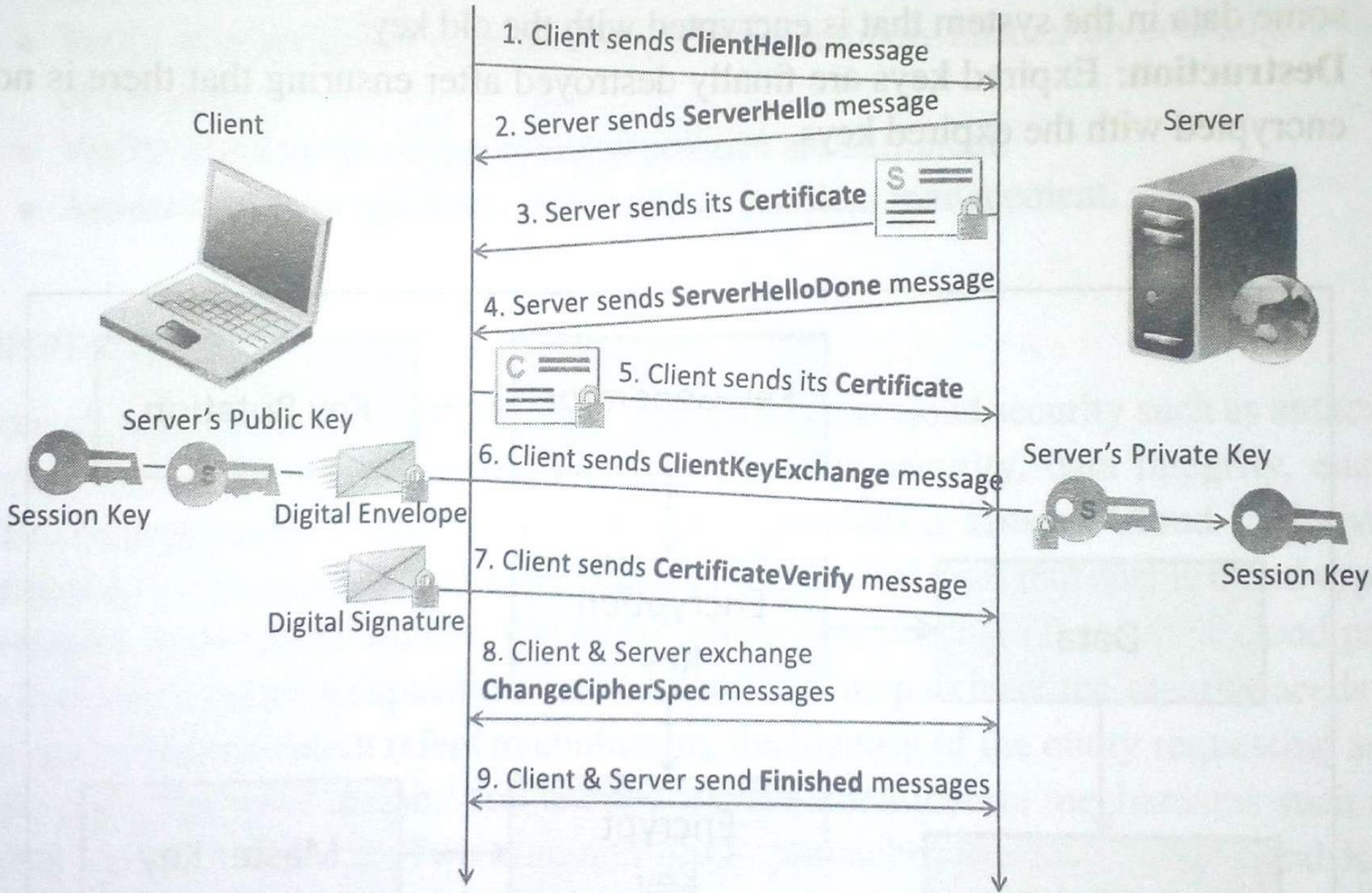


Fig : TLS Handshake

Data Security

2. **Server Hello** : The server replies with the ServerHello message, containing the protocol version chosen, a random number and the settings of the private key encryption algorithms in use.
 3. **Server Certificate**: The server sends its certificate to the client.
 4. **Server Hello Done**: The server sends a ServerHelloDone message indicating to the client that it has completed handshake negotiation.
 5. **Client certificate** : The client its certificate to the server.
 6. **Client key Exchange**: The client creates a PreMaster secret(session key) encrypted with the server's public key(which is contained in the server's certificate) and it sends the encrypted session key to the server.
 7. **Certificate Verify**: The client sends a Certificate Verify message, which is a digital signature over the previous handshake meaasge using the clients certificates private key.
- The digital signature can be verified by using the clients certificate public key.

Data Security

8. **ChangeCipherSpec** : Client and server communicate to each other that the data will be exchanged from now on will be encrypted with the session key previously exchanged.
 9. **Finished** : The client sends an encrypted message indicating the end of the handshake session, the server responds with its finished message.
- At this point the handshake phase is completed and the client and server use the session key to encrypt and decrypt the data that they mutually exchange to validate the integrity.

Key Management

- Management of encryption keys is critical to ensure security of encrypted data.

Phases of Key management life cycle :

1. Creation

- Keys must be created in a secure environment and must have adequate strength.
- It is recommended to encrypt the keys themselves with a separate master key.

2. Backup

- Backup of keys must be made before putting them into production because in the event of loss of keys, all encrypted data can become useless.

3. Deployment

- A new key is deployed for encrypting data. Deployment of a new key involves re-keying existing data.

Key Management

4. Monitoring

- After a key has been deployed, monitoring the performance of the encryption environment is done to ensure that the key has been deployed correctly.

5. Rotation

- Key rotation involves creating a new key and re-encrypting all data with the new key.

6. Expiration

- Key expiration begins after the key rotation is completed.
- It is recommended to complete the key rotation process before the expiry of the existing key.

Key Management

7. Archival

- Archival is the phase before the key is finally destroyed.
- It is recommended to archive old keys for some period of time to account for scenarios where there is still some data in the system that is encrypted with old keys.

8. Destruction

- Expired keys are finally destroyed after ensuring that there is no data encrypted with the expired keys.

Key Management

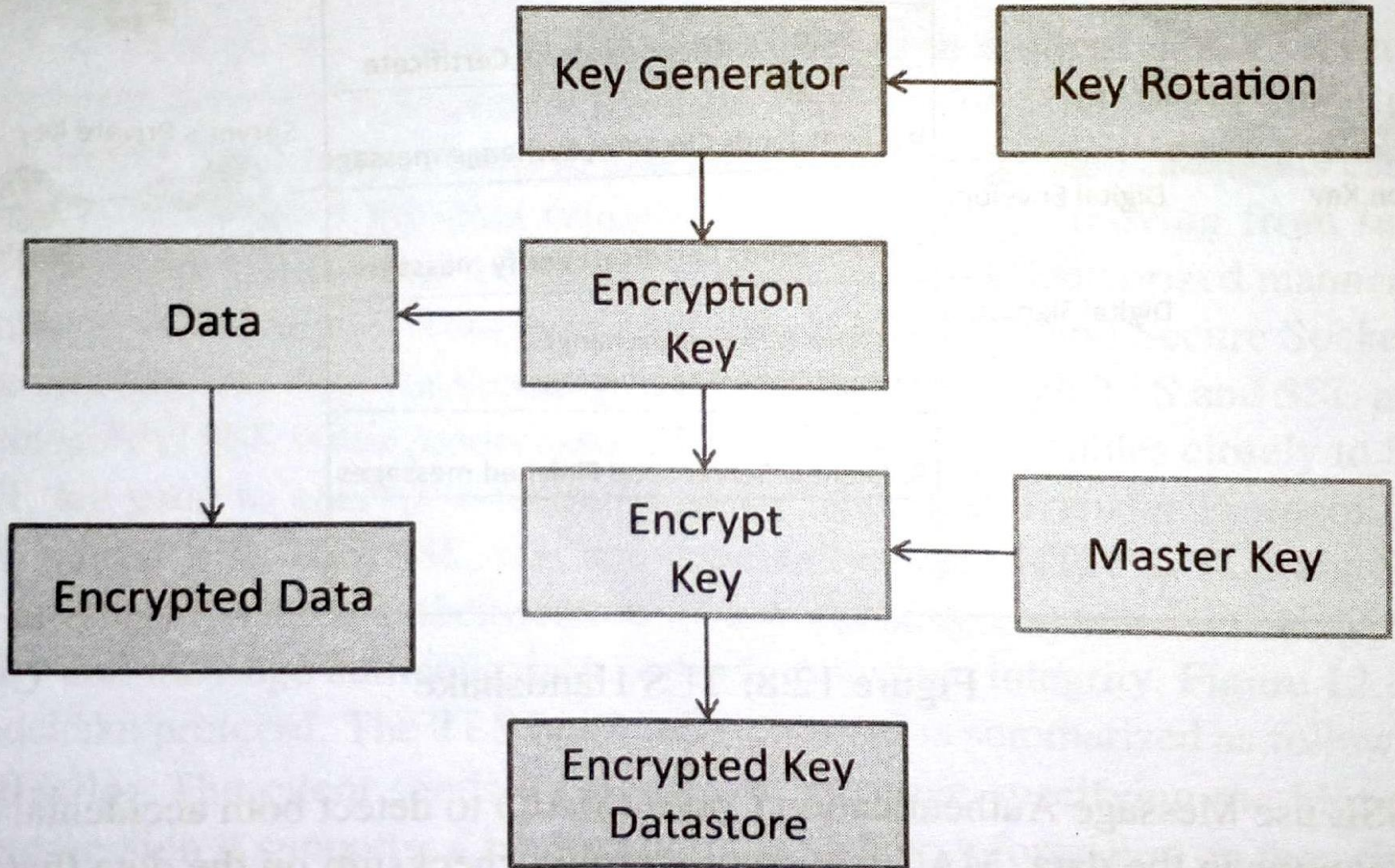


Fig : Key Management Approach

Auditing

- Auditing is mandated by most data security regulations.
- Auditing requires that all read and write access to data be logged.
- Logs can include the user involved, type of access, time stamp, actions performed and records accessed.
- The main purpose of auditing is to find security breaches, so that necessary changes can be made in the application and deployment to prevent a further security breaches.
- Objective of Auditing include :
 1. Verify efficiency and compliance of identity and access management controls as per established policies.
 2. Verify that authorized users are granted access to data and services based on their roles.
 3. Verify whether access policies are updated in a timely manner upon change in the roles of the user.
 4. Verify data protection policies are sufficient and problem management.

Thank You